ZAP by Checkmarx Scanning Report

Generated with  ZAP on Fri 6 Nov 2026, at 15:43:35

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- http://127.0.0.1:4280
- http://127.0.0.1

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	1 (10.0%)	0 (0.0%)	1 (10.0%)
	Medium	0 (0.0%)	1 (10.0%)	1 (10.0%)	0 (0.0%)	2 (20.0%)
	Low	0 (0.0%)	2 (20.0%)	3 (30.0%)	0 (0.0%)	5 (50.0%)
	Informational	0 (0.0%)	1 (10.0%)	1 (10.0%)	0 (0.0%)	2 (20.0%)
	Total	0 (0.0%)	4 (40.0%)	6 (60.0%)	0 (0.0%)	10 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://127.0.0.1:4280	1 (1)	2 (3)	5 (8)	2 (10)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
PHP Version with Known Vulnerabilities	High	1 (10.0%)
Content Security Policy (CSP) Header Not Set	Medium	3 (30.0%)
Missing Anti-clickjacking Header	Medium	2 (20.0%)
Cookie without SameSite Attribute	Low	1 (10.0%)
In Page Banner Information Leak	Low	1 (10.0%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	3 (30.0%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	5 (50.0%)

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

Alert type	Risk	Count
X-Content-Type-Options Header Missing	Low	5 (50.0%)
Authentication Request Identified	Informational	1 (10.0%)
Session Management Response Identified	Informational	3 (30.0%)
Total		10

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	4
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with content type text/plain	100 %
Info	Informational	http://127.0.0.1	Percentage of endpoints with method GET	100 %
Info	Informational	http://127.0.0.1	Count of total endpoints	1
Info	Informational	http://127.0.0.1:4280	Percentage of responses with status code 2xx	20 %
Info	Informational	http://127.0.0.1:4280	Percentage of responses with status code 3xx	77 %
Info	Informational	http://127.0.0.1:4280	Percentage of responses with status code 4xx	2 %
Info	Informational	http://127.0.0.1:4280	Percentage of endpoints with content type image/png	14 %
Info	Informational	http://127.0.0.1:4280	Percentage of endpoints with content type text/css	14 %
Info	Informational	http://127.0.0.1:4280	Percentage of endpoints with content type text/html	57 %
Info	Informational	http://127.0.0.1:4280	Percentage of endpoints with content type text/plain	14 %
Info	Informational	http://127.0.0.1:4280	Percentage of endpoints with method GET	85 %
Info	Informational	http://127.0.0.1:4280	Percentage of endpoints with method POST	14 %
Info	Informational	http://127.0.0.1:4280	Count of total endpoints	7

Alerts

1. **Risk=High, Confidence=Medium (1)**
    1. **http://127.0.0.1:4280 (1)**
        1. **PHP Version with Known Vulnerabilities (1)**
            1. ▶ GET http://127.0.0.1:4280/
2. **Risk=Medium, Confidence=High (1)**
    1. **http://127.0.0.1:4280 (1)**
        1. **Content Security Policy (CSP) Header Not Set (1)**
            1. ▶ GET http://127.0.0.1:4280/

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

3. **Risk=Medium, Confidence=Medium (1)**
    1. **http://127.0.0.1:4280 (1)**
        1. **Missing Anti-clickjacking Header (1)**
            1. ▶ GET http://127.0.0.1:4280/
4. **Risk=Low, Confidence=High (2)**
    1. **http://127.0.0.1:4280 (2)**
        1. **In Page Banner Information Leak (1)**
            1. ▶ GET http://127.0.0.1:4280/sitemap.xml
        2. **Server Leaks Version Information via "Server" HTTP Response Header Field (1)**
            1. ▶ GET http://127.0.0.1:4280/
5. **Risk=Low, Confidence=Medium (3)**
    1. **http://127.0.0.1:4280 (3)**
        1. **Cookie without SameSite Attribute (1)**
            1. ▶ GET http://127.0.0.1:4280/
        2. **Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)**
            1. ▶ GET http://127.0.0.1:4280/
        3. **X-Content-Type-Options Header Missing (1)**
            1. ▶ GET http://127.0.0.1:4280/
6. **Risk=Informational, Confidence=High (1)**
    1. **http://127.0.0.1:4280 (1)**
        1. **Authentication Request Identified (1)**
            1. ▶ POST http://127.0.0.1:4280/login.php
7. **Risk=Informational, Confidence=Medium (1)**
    1. **http://127.0.0.1:4280 (1)**
        1. **Session Management Response Identified (1)**
            1. ▶ GET http://127.0.0.1:4280/

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

1. **PHP Version with Known Vulnerabilities**

Source	raised by a passive scanner (Server Side Technology Version with Known Vulnerabilities)
CWE ID	1395
WASC ID	13
Reference	1. https://www.php.net/supported-versions.php 2. https://github.com/php/php-src/security/advisories 3. https://www.zaproxy.org/docs/desktop/addons/passive-scan-rules/php-known-vulnerabilities/#cve-2026-109618 4. https://www.zaproxy.org/docs/desktop/addons/passive-scan-rules/php-known-vulnerabilities/#cve-2026-109619

2. **Content Security Policy (CSP) Header Not Set**

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP 2. https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html 3. https://www.w3.org/TR/CSP/ 4. https://w3c.github.io/webappsec-csp/ 5. https://web.dev/articles/csp 6. https://caniuse.com/#feat=contentsecuritypolicy 7. https://content-security-policy.com/

3. **Missing Anti-clickjacking Header**

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	1. https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

4. **Cookie without SameSite Attribute**

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	1. https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

5. **In Page Banner Information Leak**

Source	raised by a passive scanner (In Page Banner Information Leak)
CWE ID	497
WASC ID	13

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF

Reference
1. https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

6. **Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**

Source raised by a passive scanner (Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))
CWE ID 497
WASC ID 13
Reference
1. https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
2. https://www.troyhunt.com/shhh-dont-let-your-response-headers/

7. **Server Leaks Version Information via "Server" HTTP Response Header Field**

Source raised by a passive scanner (HTTP Server Response Header)
CWE ID 497
WASC ID 13
Reference
1. https://httpd.apache.org/docs/current/mod/core.html#servertokens
2. https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)
3. https://www.troyhunt.com/shhh-dont-let-your-response-headers/

8. **X-Content-Type-Options Header Missing**

Source raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID 693
WASC ID 15
Reference
1. https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
2. https://owasp.org/www-community/Security_Headers

9. **Authentication Request Identified**

Source raised by a passive scanner (Authentication Request Identified)
Reference
1. https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

10. **Session Management Response Identified**

Source raised by a passive scanner (Session Management Response Identified)
Reference
1. https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

Explore our developer-friendly HTML to PDF API Printed using PDFCrowd HTML to PDF